



ISO

27001/27002:2022

This document is property of Data & More ApS and commercial in confidence. The document is intended to be read with the permission of Data & More ApS only. If you do not have explicit permit to read the document, stop reading the document and contact the document owner immediately.

Kristian Boe Helweg Hansen

using Cyberday.ai

07.08.2026, 11:11

Version #3



Category	Requirement			
27001 contents: 4.1 - 10.2	4.1	4.2	4.3	4.4
	5.1	5.2	5.3	6.1
	6.2	6.3	7.1	7.2
	7.3	7.4	7.5	8.1
	8.2	8.3	9.1	9.2
	9.3	10.1	10.2	
5: Governance	5.1	5.2	5.3	5.4
	5.5	5.6	5.8	5.24
5, 7 & 8: Asset management	5.9	5.10	5.11	5.14
	7.8	7.10	8.1	
5 & 8: Information protection	5.12	5.13	5.34	8.10
	8.11	8.12	8.33	
5 & 8: Identity and access management	5.15	5.16	5.17	5.18
	8.2	8.3	8.4	8.5
5 & 8: Supplier relationships	5.19	5.20	5.21	5.22
	5.23	8.30		
5 & 8: Continuity	5.29	5.30	8.6	8.13
	8.14			
5: Legal and compliance	5.31	5.32	5.33	5.35
	5.36	5.37		
6: Human resource security	6.1	6.2	6.3	6.4
	6.5	6.6	6.7	
7: Physical security	7.1	7.2	7.3	7.4
	7.5	7.6	7.7	7.9
	7.11	7.12	7.13	7.14

Category	Requirement								
8: System and network security	<table><tr><td>8.7</td><td>8.20</td><td>8.21</td><td>8.22</td></tr><tr><td>8.23</td><td>8.34</td><td></td><td></td></tr></table>	8.7	8.20	8.21	8.22	8.23	8.34		
8.7	8.20	8.21	8.22						
8.23	8.34								
8 & 5: Threat and vulnerability management	<table><tr><td>5.7</td><td>8.8</td></tr></table>	5.7	8.8						
5.7	8.8								
8, 5 & 6: Information security event management	<table><tr><td>5.25</td><td>5.26</td><td>5.27</td><td>5.28</td></tr><tr><td>6.8</td><td>8.15</td><td>8.16</td><td>8.17</td></tr></table>	5.25	5.26	5.27	5.28	6.8	8.15	8.16	8.17
5.25	5.26	5.27	5.28						
6.8	8.15	8.16	8.17						
8: Secure configuration	<table><tr><td>8.9</td><td>8.18</td><td>8.19</td><td>8.24</td></tr></table>	8.9	8.18	8.19	8.24				
8.9	8.18	8.19	8.24						
8: Application security	<table><tr><td>8.25</td><td>8.26</td><td>8.27</td><td>8.28</td></tr><tr><td>8.29</td><td>8.31</td><td>8.32</td><td></td></tr></table>	8.25	8.26	8.27	8.28	8.29	8.31	8.32	
8.25	8.26	8.27	8.28						
8.29	8.31	8.32							


DATA & MORE

27001 contents: 4.1 - 10.2

4.1

Organization and its context

Applicable: Based on risk treatment

The organization must identify external and internal factors affecting its ability to achieve information security goals. The organization must also assess if climate change is a relevant issue (Amd 1:2024).

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Adequate


Evidence: Strong

Owner	Task name	Evidence	Status
KH	ISMS description and maintenance	ISMS description and scope Report	Fully done

Understanding the needs and expectations of interested parties is vital. The organization should identify relevant interested parties, determine their requirements, and decide how these requirements will be addressed in the information security management system. The organization should also consider if any relevant stakeholders have climate change related requirements (Amd 1:2024).

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Adequate

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Data processing partner listing and owner assignment	Data processors (4)	Fully done
		 Partner management	
		System providers (14)	
		 Partner management	
LT	Documentation of customer groups whose information is processed by the organization	Customers (3)	Fully done
		 Partner management	
LT	Documentation of other stakeholders	Other stakeholders (5)	Fully done
		 Partner management	

4.3 Scope of the ISMS

Applicable: Based on risk treatment

The organization needs to define the boundaries and applicability of its information security management system, considering external and internal issues, requirements, and interfaces with other organizations.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done

4.4 Information security management system

Applicable: Based on risk treatment

The organization is required to establish, implement, maintain, and continually improve an information security management system, ensuring compliance with the specified requirements.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done
DJ	Regular internal monitoring of the implementation of the information security management system	Monitoring task implementation: The ISMS (In...  Process description	Fully done

5.1 Leadership and commitment

Applicable: Based on risk treatment

Top management should demonstrate leadership and commitment to the information security management system (ISMS), including establishing policies, integrating requirements, providing resources, and promoting continual improvement.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Defining and documenting security objectives	Security objectives (9)  Risk management and leadership	Fully done
KH	Communication plan for information security management system	1. Objectives and Goals Objective: Ensur...  Process description	Fully done
KH	Management commitment to cyber security management and management system	ISMS description and scope  Report	Fully done

5.2 Policy

Applicable: Based on risk treatment

Top management must create an information security policy aligned with the organization's purpose, incorporating objectives, a commitment to compliance, and a commitment to continual improvement.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Information security policy -report publishing, informing and maintenance	Information security policy and objectives  Report	Fully done

Top management should ensure that roles related to information security have assigned responsibilities and authorities, including oversight of the information security management system.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
SC	Amount, competence and adequacy of key cyber security personnel	Trainings and exercises (3)  Personnel security	Fully done

6.1 Information security risk management

Applicable: Based on risk treatment

The organization must identify risks and opportunities, plan actions to address them, and integrate these actions into the ISMS. Also information security risk assessment needs to be conducted, identifying, analyzing, and evaluating risks, and producing a Statement of Applicability. In addition a risk treatment process needs to be defined and applied, creating a risk treatment plan, retaining documented

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
K	Creating and maintaining a statement of applicability	ISO 27001/27002:2022  Report	Fully done
DJ	Identification and documentation of cyber security risks	Cyber security risks (222)  Risk management and leadership	Fully done
K	Risk management procedure -report publishing and maintenance	Risk management procedure and result preview  Report	Fully done
DJ	Risk level accepted by the organization	Acceptable risk level determination: The orga...  Process description	Fully done

6.2 Information security objectives

Applicable: Based on risk treatment

Organization must establish measurable information security objectives, considering policy, requirements, risk assessment, and treatment. Plans should detail what, who, when, and how objectives will be achieved.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Defining and documenting security objectives	Security objectives (9)  Risk management and leadership	Fully done

6.3 Planning of changes

Applicable: Based on risk treatment

Organized planning is required when changes to the information security management system are deemed necessary.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done
DJ	Evaluation process and documentation of significant security-related changes	Change risk assessments (3)  Risk management and leadership	Fully done

The organization must determine and provide resources necessary for establishing, implementing, maintaining, and improving the information security management system.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Management commitment to cyber security management and management system	ISMS description and scope  Report	Fully done

The organization should determine the required competence of individuals affecting information security and provide necessary training to the personnel when needed. Appropriate documentation as evidence of competence can be retained.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
SC	Amount, competence and adequacy of key cyber security personnel	Trainings and exercises (3)  Personnel security	Fully done

Persons working under the organization must be aware of the information security policy, understand their contribution to the system's effectiveness, and know the implications of non-conformance.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
K	Disciplinary process for security breaches	Assessment of intentionality: The organizatio...  Process description	Fully done

Organization needs to determine the need for internal and external communications regarding the information security management system. Following things should be considered: what to communicate, when to communicate, with whom to communicate and how.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Communication plan for information security management system	1. Objectives and Goals  Process description	Objective: Ensur... Fully done

Documented information for the information security management system must include what is required by the standard and what the organization deems necessary for effectiveness. Proper identification, format, and review procedures should be followed when creating and updating documented information. Documented information must be controlled to ensure availability, suitability, and protection, with

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
K	Creating and maintaining a statement of applicability	ISO 27001/27002:2022  Report	Fully done
KH	Information security policy -report publishing, informing and maintenance	Information security policy and objectives  Report	Fully done
KH	Internal audit procedure -report publishing and maintenance	Internal audit procedure and results  Report	Fully done
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done
K	Risk management procedure -report publishing and maintenance	Risk management procedure and result preview  Report	Fully done
KH	Maintaining chosen theme-specific policy documents	Organization has created necessary policy do...  Process description	Fully done

Processes must be planned, implemented, and controlled to meet requirements and address identified risks. Documented information is necessary to confirm the successful execution of processes. The organization should manage planned changes and assess the impact of unintended changes, taking necessary actions to minimize any negative effects. Additionally, the organization must control externally

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Information security policy -report publishing, informing and maintenance	Information security policy and objectives  Report	Fully done
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done
DJ	Evaluation process and documentation of significant security -related changes	Change risk assessments (3)  Risk management and leadership	Fully done
DJ	Regular internal monitoring of the implementation of the information security management system	Monitoring task implementation: The ISMS (In...  Process description	Fully done

8.2 Information security risk assessment

Applicable: Based on risk treatment

Organization must perform information security risk assessments at planned intervals or when significant changes occur, retaining documented information of the results.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Identification and documentation of cyber security risks	Cyber security risks (222)  Risk management and leadership	Fully done
K	Risk management procedure -report publishing and maintenance	Risk management procedure and result preview  Report	Fully done

8.3 Information security risk treatment

Applicable: Based on risk treatment

The organization is required to implement the information security risk treatment plan, retaining documented information of the results.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Identification and documentation of cyber security risks	Cyber security risks (222)  Risk management and leadership	Fully done
K	Documentation of linked risks for identified security incidents	Security incidents (2)  Incident management Personal data breaches (5)  Incident management	Fully done

Organization should determine what to monitor and measure in terms of information security processes and controls. It's important to establish effective methods for monitoring, measurement, analysis, and evaluation to ensure valid and comparable results. The organization needs to specify when these monitoring and measuring activities should occur and assign responsibilities for these tasks.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
K	Defining and documenting cyber security metrics	Cyber security metrics (5)  Risk management and leadership	Fully done

Internal audits should be conducted at planned intervals to assess conformity to requirements and the effectiveness of the information security management system.

The organization must plan, establish, and maintain an internal audit program, considering the

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Executing and documenting internal audits	Audits (1)  Risk management and leadership	Fully done
KH	Internal audit procedure - report publishing and maintenance	Internal audit procedure and results  Report	Fully done

Top management is responsible for reviewing the information security management system at planned intervals to ensure its continuing suitability, adequacy, and effectiveness. These reviews must consider various inputs, including actions from previous reviews, changes in external/internal issues, and feedback on performance and risks. Management review results should include decisions related to

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Evaluation process and documentation of significant security-related changes	Change risk assessments (3)  Risk management and leadership	Fully done
KH	Implementation and documentation of management reviews	Management reviews (1)  Risk management and leadership	Fully done

The organization needs to continually improve the suitability, adequacy, and effectiveness of the information security management system.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Continuous improvement and documentation	Improvements (17)  Risk management and leadership	Fully done

When nonconformities occur, the organization should react, evaluate causes, implement corrective actions, and make necessary changes to the information security management system. Documented information is essential to record nonconformities and corrective action results. It's also beneficial to determine if similar nonconformities exist, or could potentially occur.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Treatment process and documentation of identified non-conformities	Nonconformities (6)	Fully done
		 Risk management and leadership	

5: Governance

Establishing and maintaining strong information security policy is important for any organization. It involves creating an overarching policy aligned with business needs, regulations, and security risks, along with topic specific policies for different security areas like access control and incident management.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Information security policy -report publishing, informing and maintenance	Information security policy and objectives  Report	Fully done
KH	ISMS description and maintenance	ISMS description and scope  Report	Fully done
KH	Maintaining chosen theme -specific policy documents	Organization has created necessary policy do...  Process description	Fully done
KH	Formal adoption of security policies	Acceptance of information security policy: Th...  Process description	Fully done

Defining information security roles and responsibilities based on organizational needs is essential to establish a clear structure for information security management. Responsibilities include protecting assets, executing information security processes and managing risks. Organizational approaches to information security management vary based on size and resources, ranging from dedicated roles to

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
SC	Amount, competence and adequacy of key cyber security personnel	Trainings and exercises (3)  Personnel security	Fully done
KH	Defining security roles and responsibilities	Information security policy and objectives  Report	Fully done

Segregation of duties is implemented to separate conflicting responsibilities among individuals, aiming to prevent one person from performing conflicting tasks alone and reducing the risk of fraud and error while maintaining information security.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Segregation of information security related duties	Segregation of information security -related d...  Process description	Fully done

Management's responsibility is to make sure all staff are aware and follow the information security rules outlined in the company policies and procedures. Management needs to comprehend their pivotal role in information security and take necessary actions to ensure that all employees are fully aware of their information security responsibilities. Employees should also understand their role of ensuring that their

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
KH	General security competence and awareness of personnel	Personnel security guidelines and acceptance procedure  Report	Fully done
KH	Management commitment to cyber security management and management system	ISMS description and scope  Report	Fully done

The organization must establish and uphold communication channels with relevant authorities to ensure a proper exchange of information regarding information security between the organization and the corresponding legal, regulatory, and supervisory entities.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
K	Reporting personal data breaches to authorities / data subjects	Personal data breaches: Notifications (5)  Incident management	Fully done
KH	Keeping contact with relevant authorities	Establishment of government actors list: The ...  Process description	Fully done

5.6 Contact with special interest groups

Applicable: Based on risk treatment

The organization should create and uphold connections with special interest groups or other specialized security forums and professional associations in order to facilitate the proper exchange of information concerning information security. These contacts can provide many benefits for example a good way to stay tuned on the best practices of the industry, offer early warnings of potential threats and grant

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
A	Contact with industry - specific interest groups	Other stakeholders (5)  Partner management	Fully done

5.8 Information security in project management

Applicable: Based on risk treatment

Integration of information security within project management is vital to effectively handle information security risks associated with projects and deliverables throughout the entire project life cycle.

Information security requirements should be determined using various methods and can be derived from

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Process for including information security aspects in project management	Based on the document titled IT Security Ass...  Process description	Fully done

Organizations should plan and prepare for managing information security incidents by defining, establishing, and communicating incident management processes, roles, and responsibilities. This is essential to ensure an effective, consistent, and orderly response to information security incidents.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Incident management resourcing and monitoring	Requirements for Incident Management Reso...  Process description	Fully done

5, 7 & 8: Asset management

Organizations should create and sustain a comprehensive record of information and related resources, along with their respective owners. Organization needs to recognize information and associated assets to safeguard their security and properly allocate ownership.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Data system listing and owner assignment	Data systems (7)  System management	Fully done
KH	Data store listing and owner assignment	Data stores (15)  Privacy	Fully done
KH	Documentation of data sets for data stores	Data sets (15)  Management of data sets	Fully done
KH	Documentation of assets inventories outside the ISMS	Inventorying information assets: The organiza...  Process description	Fully done
DJ	Documentation of other protected assets	Other assets (0)  Physical security Offices (5)  Physical security	Fully done
KH	Listing offered digital services and naming owners	Offered cloud services (1)  Development and cloud	Fully done
KH	Documentation of personal data outside data systems	Other data archives (1)  Management of data sets	Fully done

Guidelines outlining the proper utilization and protocols for managing information and related assets must be recognized, recorded, and put into practice. This is done to guarantee the adequate protection, utilization, and responsible management of information and its associated assets.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
KH	Personnel guidelines for file usage and local data	Data set management guidelines (5)  Employee awareness	Fully done
K	Personnel guidelines for reporting security incidents	Incident management guidelines (7)  Employee awareness	Fully done
DJ	Personnel guidelines for safe data system and authentication info usage	System management guidelines (6)  Employee awareness	Fully done
KH	Personnel guidelines for safe disposal of paper data	Data set management guidelines (5)  Employee awareness	Fully done
KH	Personnel guidelines for safe processing of personal and confidential data	Privacy guidelines (5)  Employee awareness	Fully done
DJ	Personnel guidelines for safe usage of mobile devices	Remote work and mobile device guidelines (13)  Employee awareness	Fully done

Upon change or termination of their employment, contract, or agreement, personnel and relevant parties must return all organization-owned assets in their possession to safeguard the organization's property during the transition process.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Process for removing hardware and access rights at termination of employment relationship	Exit checklist: The organization has implemen...  Process description	Fully done
KH	Special supervision of dismissed workers	Task: Special Supervision of Dismissed Work...  Process description	Fully done

The organization should have rules and procedures in place for the transfer of information within an organization and between the organization and external parties. This is crucial for ensuring the security of the transferred information. Rules and procedures should cover all kinds of methods of transfer, e.g. electronic, physical storage media and verbal transfer.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Data processing partner listing and owner assignment	Data processors (4)	Fully done
		 Partner management	
		System providers (14)	
		 Partner management	
KH	Maintaining confidentiality agreements	Definition of confidential information: The agr...	Fully done
		 Process description	
KH	Personnel guidelines for avoiding phishing	Email and phishing guidelines (7)	Fully done
		 Employee awareness	
DJ	Using a selected web browser and checking for updates	Google Chrome is the default browser chosen...	Fully done
		 Process description	
DJ	Email authentication: DKIM	DKIM settings are managed centrally in Cloud...	Fully done
		 Process description	
DJ	Email authentication: DMARC	Postmaster tools (e.g. Google Postmaster Too...	Fully done
		 Process description	
DJ	Email authentication: SPF	SPF settings are managed centrally in Cloudfl...	Fully done
		 Process description	
DJ	Enabling and configuring mailbox audit logs	 No security system linked	Fully done
KH	Inventory and documentation of data processing agreements	Data processors (4)	Fully done
		 Partner management	
		System providers (14)	
		 Partner management	
DJ	Mailbox audit log monitoring	Mailbox audit log is enabled, the events is sav...	Fully done
		 Process description	
DJ	Use of anti-phishing policies	 No security system linked	Fully done

Organization should ensure that equipment is securely located and protected to minimize risks from physical and environmental threats, as well as unauthorized access and potential damage. Implementing controls is essential to minimize potential physical and environmental threats. These threats include theft, fire, explosives, smoke, water-related risks, dust, vibration, chemical effects, electrical supply

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Safe placement of equipment	Physical security policy  Report	Fully done
DJ	Alarm systems for equipment environment	 No security system linked	Fully done
DJ	Electromagnetic data breach management	Openings in the Hetzner' structures (windows...  Process description	Fully done
DJ	Lightning protection	All Hetzner buildings and all incoming power l...  Process description	Fully done

Organizations should manage storage media throughout their life cycle, including acquisition, use, transportation, and disposal, following the organization's classification scheme and handling requirements. Management practices for storage media should effectively prevent unauthorized disclosure, modification, removal, or destruction.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Defining the types of removable media used	By default, the use of removable media in an ...  Process description	Fully done
DJ	Safe disposal of laptops	Unnecessary laptops are collected by the IT d...  Process description	Fully done
KH	Locked cabinets for storing devices including confidential data	No media containing confidential data must b...  Process description	Fully done
KH	Detailed rules for the management of removable media	Process: Prohibition of Using Portable Storag...  Process description	Fully done
KH	Securing the physical transport of data, devices and media	Third parties are used to transport informatio...  Process description	Fully done

Organization needs to make sure that all information that is accessed, stored or processed on personnel's endpoint devices is protected. Information needs to be protected from the risks that occur when people are using their devices.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Personnel guidelines for safe usage of mobile devices	Remote work and mobile device guidelines (13)  Employee awareness	Fully done
DJ	Process for theft / disappearance of mobile equipment	When a mobile device is lost, the employee m...  Process description	Fully done
DJ	Endpoint security management system	 <i>No security system linked</i>	Fully done
DJ	Mobile device security policies and their monitoring	Mobile Device Security Policies and Monitorin...  Process description	Fully done
DJ	Using a mobile device management system	 Google Cloud Identity  External system	Fully done

5 & 8: Information protection

The information should be classified based on the organization's information security requirements, considering factors such as confidentiality, integrity, availability, and relevant stakeholder needs. The goal is to identify and understand the protection needs of information based on its relevance to the organization. Classifying information streamlines its management and protection, minimizing the

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Definition of data classifications and class-specific security procedures	Data classification and handling policy  Report	Fully done
KH	Documentation of data classes for data sets	Data sets: Class (15)  Management of data sets	Fully done

Organizations should develop and implement procedures for information labeling in alignment with the organization's classification scheme to improve communication and enable automation of information processing and management. Personnel and relevant parties should be informed about labeling procedures. Comprehensive training should be available to ensure accurate labeling and proper handling

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Definitions and instructions on information classifications		Fully done
KH	Marking of equipment that needs safe disposal	Established disposal procedures: The organiz...  Process description	Fully done

Organization must identify and fulfill the requirements related to preserving privacy and safeguarding Personally Identifiable Information (PII) as per applicable laws, regulations, and contractual obligations. This is crucial to ensuring compliance with requirements concerning the information security aspects of PII protection.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Appointment, tasks and position of a Data Protection Officer (DPO)	The Data Compliance Manager has been nam...  Process description	Fully done
KH	Documentation of personal data processing purposes for data stores	Data stores: Purposes (15)  Privacy	Fully done
K	Management and documentation of data breaches	Personal data breaches (5)  Incident management	Fully done
KH	Personnel guidelines for safe processing of personal and confidential data	Privacy guidelines (5)  Employee awareness	Fully done
KH	Privacy notices - report publishing and maintenance	Data stores: Informing (15)  Privacy	Fully done
KH	Process for receiving and handling data subject requests	Description not filled	Fully done

Organization needs to make sure information is deleted when it's no longer needed from systems, devices, or storage. This helps protect sensitive data and meets legal, regulatory, and contract rules for information removal. When third parties store an organization's information, the organization should incorporate information deletion requirements into agreements, ensuring enforcement during and after

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Archiving and destruction processes for data sets	Retention periods documented: The organizat...  Process description	Fully done
KH	Defining and documenting retention times for data sets	Data sets: Retention (15)  Management of data sets	Fully done

8.11 Data masking

Applicable: Based on risk treatment

Organization should use data masking according to the organization's policies and business needs. This helps safeguard sensitive data, including Personally Identifiable Information (PII), and ensures compliance with legal and contractual requirements. Data masking can be done by e.g. encryption, nulling or deleting characters to prevent unauthorized users from seeing full messages and replacing

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Defining and implementing masking for confidential data	Requirements for Defining and Implementing ...  Process description	Fully done
KH	Anonymization of personal data	 No security system linked	Fully done
KH	Pseudonymisation of personal data	 No security system linked	Fully done

Organization should implement measures to prevent data leakage on systems, networks, and devices handling sensitive information. These measures aim to identify and stop unauthorized individuals or systems from disclosing or extracting sensitive data.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Definition of data classifications and class-specific security procedures	Data classification and handling policy  Report	Fully done
KH	Personnel guidelines for file usage and local data	Data set management guidelines (5)  Employee awareness	Fully done
KH	Minimization of information outside data systems	Identification of valuable information conduct...  Process description	Fully done
DJ	Use of a DLP-system	 No security system linked	Fully done
KH	Using data loss prevention policies	 No security system linked	Fully done

Organization needs to choose, safeguard, and handle test information thoughtfully to ensure that testing remains relevant and operational information used for testing is protected. Information used in testing should receive the same level of attention and care as operational information to prevent any information leaking outside the organization.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Protection and minimisation of test data	All testing is performed in a staging environm...  Process description	Fully done
DJ	Specific safeguards for production data used for testing	Description not filled	Fully done

5 & 8: Identity and access management

Organization should create rules for who can access information and related assets, both physically and electronically. The goal is to allow authorized access while preventing unauthorized access. Information and asset owners should establish security and business requirements for sufficient access control. This should be reflected in a specific access control policy and communicated to relevant stakeholders.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Defining and documenting access roles	Access roles (5)  System management	Fully done
KH	Need to know - principle in access management	Access management and password policy  Report	Fully done
DJ	Implementing formal access control processes	Access management and password policy  Report	Fully done

The organization should actively manage the complete life cycle of identities to uniquely identify individuals and systems accessing organizations information and assets. For example individual identities should be uniquely linked to a single person to ensure accountability for their actions. Shared identities, assigned to multiple individuals, are only allowed when necessary for business or operational

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Process for granting access rights at the start of employment relationships	Single access provision: When a person start...  Process description	Fully done
KH	Process for removing hardware and access rights at termination of employment relationship	Exit checklist: The organization has implemen...  Process description	Fully done
DJ	Avoiding and documenting shared user accounts	Purpose:To ensure individual accountability, ...  Process description	Fully done

Organization needs to require a controlled management process for handling authentication information, this includes guiding personnel on secure authentication practices e.g. best practices for password selection. Implementing single sign-on (SSO) or other authentication management tools, such as password vaults, reduces the volume of authentication information users need to safeguard.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Defining and documenting accepted authentication methods	Data systems: Access roles (7)  System management	Fully done
DJ	Personnel guidelines for safe data system and authentication info usage	System management guidelines (6)  Employee awareness	Fully done
DJ	Use and evaluation of password management system	 Microsoft Authenticator OpenVPN  External system	Fully done
DJ	Managing shared user credential through password management system	Purpose:The purpose of managing shared us...  Process description	Fully done
DJ	Credentials are not transmitted via email	Purpose:The purpose of this process is to pre...  Process description	Fully done
DJ	Secure setting and distribution of temporary login information	Task: Secure Setting and Distribution of Temp...  Process description	Fully done

Access to information and related assets must follow the organization's access control policy, this involves setting up, reviewing, modifying, and removing access rights in line with the Organization's rules. The process of assigning or revoking access rights can involve e.g. obtaining authorization from asset owners, with separate management approval if necessary, addressing segregation of duties,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Regular reviewing of data system access rights	Determination of access roles by data system...  Process description	Fully done
DJ	Instructions for reporting changes affecting access rights	Process Description: Instructions for Reportin...  Process description	Fully done
KH	Review of access right for changed employee roles	Access rights review: The organization has d...  Process description	Fully done
KH	Arranging training and guidance during orientation (or before granting access rights)	Guidance on security responsibilities: Before ...  Process description	Fully done
DJ	Identification and management of shadow IT	 GitHub D&M Compliance server  External system	Fully done
KH	Restriction of access rights at high risk times of employment	Reduction of access rights upon employment ...  Process description	Fully done

Organization should restrict and manage privileged access to ensure only approved users, software, and services have those rights. The assignment of privileged access rights must be regulated through an authorization process aligned with the pertinent topic-specific policy on access control.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Rules and formal management process for admin rights	Purpose: The purpose of this process is to def...  Process description	Fully done
DJ	Use of dedicated admin accounts in critical data systems	Dedicated use of administrator accounts: The...  Process description	Fully done
DJ	Using multi-factor authentication for admins	 Google Authenticator D&M Compliance server  External system	Fully done

Organization should limit access to information and related resources following a specific access policy to allow only authorized entry and prevent unauthorized access. To uphold access restriction requirements, consider restricting access to sensitive information from unknown or anonymous user identities, implementing configuration mechanisms for controlling access in systems, applications, and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Defining and documenting access roles	Access roles (5)  System management	Fully done
DJ	Access management for files stored in the cloud	D&M Compliance server  External system	Fully done

8.4 Access to source code

Applicable: Based on risk treatment

Organization should manage access to source code, development tools, and software libraries to control both reading and writing. This helps prevent unwanted changes, keeps things secure, and safeguards valuable ideas. For example when an organization utilizes open-source or third-party code components, it is permissible to grant broad read access to external code repositories while restrictions are maintained

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Source code management	 No security system linked	Fully done

8.5 Secure authentication

Applicable: Based on risk treatment

Organization needs to implement secure authentication technologies and procedures in line with access restrictions and the topic-specific access policy. This ensures secure authentication for users and entities when accessing systems, applications, and services. Authentication strength must match information classification. For robust authentication, consider alternatives like digital certificates, smart

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Defining and documenting accepted authentication methods	Data systems: Access roles (7)  System management	Fully done
DJ	Use of multi-factor authentication for important data systems	Implementation of multi-authentication logon:...  Process description	Fully done
DJ	Analyzing authentication processes of critical systems	Secure password transmission: Passwords ar...  Process description	Fully done
DJ	Encryption of user password information	 No security system linked	Fully done

5 & 8: Supplier relationships

5.19 Information security in supplier relationships

Applicable: Based on risk treatment

Organization should establish and follow processes to handle security risks tied to using products or services from suppliers. This ensures that a mutually agreed-upon level of information security is maintained in supplier relationships. It's beneficial to evaluate and select suppliers' products and services that have strong information security controls. Supplier controls must ensure the integrity of

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Data processing partner listing and owner assignment	Data processors (4)	Fully done
		 Partner management	
		System providers (14)	
	Criteria for high priority partners	 Partner management	Fully done
		Defining required certifications or standards: ...	
LT		 Process description	
KH	Defining supplier types that can access confidential data	Description not filled	Fully done
DJ	Data processing agreement analysis for most important system providers	System providers: Contract (14)	Fully done
		 Partner management	

Organization needs to define and agree on information security requirements with each supplier based on the type of relationship. This is done to ensure a consistent level of information security in supplier interactions. Documented supplier agreements are crucial to establish a clear understanding between the organization and the supplier, outlining both parties' obligations to fulfill relevant information security

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Inventory and documentation of data processing agreements	Data processors (4)	Fully done
		 Partner management	
		System providers (14)	
LT	Evaluation of data processing agreement for important data processors	 Partner management	Fully done
		Processing contract evaluations (7)	
		 Partner management	

Organization should implement processes and procedures to handle information security risks in the supply chain of ICT products and services. This is crucial for maintaining a mutually agreed-upon level of information security in relationships with suppliers. To address this, organization should e.g. mandate suppliers extend security requirements throughout the supply chain when subcontracting for ICT

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
LT	Documentation of partner contract status	Data processors: Contract (4)	Fully done
		 Partner management	
		System providers: Contract (14)	
		 Partner management	
KH	Minimum requirements for partner companies to gain access to different levels of information	Supplier security policy	Fully done
		 Report	

The organization must consistently monitor, review, assess, and manage changes in supplier information security practices and service delivery, for upholding an agreed-upon level of information security and service delivery in accordance with established supplier agreements. Organization can e.g. review supplier service reports, hold progress meetings as per agreements, conduct audits on suppliers and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Adequate

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Criteria for suppliers of high priority data systems	Partners providing 'High' or 'Critical' data sys...  Process description	Fully done
SC	Defined security arrangements for providing critical network equipment	Advanced definition of security arrangements...  Process description	Mostly done
DJ	Monitoring suppliers' compliance with security requirements	Appointment of designated responsible perso...  Process description	Fully done

Organization need to establish processes for acquiring, using, managing, and exiting from cloud services that align with the organization's information security requirements. This is essential to clearly define and manage information security aspects when utilizing cloud services. It can be either integrated into the current approach for managing services offered by external parties, or serving as an extension of the

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	General principles regarding the use of cloud services	General principles for managing cloud servic...  Process description	Fully done
DJ	General rules for the procurement of data systems	When acquiring a new vendor or data system...  Process description	Fully done
DJ	Comprehensiveness of contractual terms for cloud service provisioning	Description not filled	Fully done
KH	Documenting security -related responsibilities for offered cloud services and utilized data systems	ObjectiveThe objective of this task is to clearl...  Process description	Fully done
K	Process for detecting and reporting security breaches related to the supply chain	Definition of reporting procedures: The organi...  Process description	Fully done
KH	Confirming information security roles and responsibilities related to utilized cloud services	Confirmation of security roles and responsibil...  Process description	Fully done

The organization needs to oversee, track, and assess activities related to outsourced system development. This is to make sure that the security measures required by the organization are properly implemented in the development of systems done by external partners. Organization should consider e.g. code ownership and intellectual property rights concerning outsourced content, and contractual

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Listing authorized users for publishing code changes	Only pre-defined, authorized users are allow...  Process description	Fully done

5 & 8: Continuity

The Organization should develop plans to ensure information security remains at an appropriate level even during disruptions, aiming to safeguard information and related assets in challenging circumstances. Plans must be created, tested, and regularly reviewed to sustain or restore information security in critical business processes post-disruption.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Creating and documenting continuity plans	Continuity plans (5)  Risk management and leadership	Fully done
DJ	Preparing for quick data recovery after faults	Requirements for Preparing for Quick Data Re...  Process description	Fully done
K	Regular testing and review of continuity plans	Regular testing and review of continuity plans...  Process description	Fully done
K	Requirements about information security continuity	Continuity management policy  Report	Fully done

The organization should plan, implement, maintain, and test ICT readiness aligned with business continuity objectives and ICT continuity requirements. This is done to guarantee the availability of the organization's information and other associated assets during disruptions. ICT continuity plans, including response and recovery procedures, should be regularly evaluated and approved by management.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
K	Identifying and testing the continuity capabilities required from ICT services	Continuity plans (5)  Risk management and leadership	Fully done

Organizations need to monitor their resources and make changes to match what they need. This helps them to have enough resources e.g. information processing facilities, human resources, offices, and other facilities, considering the business criticality of the relevant systems and processes. It's good to have early detection systems, so projections for future capacity can align with e.g. business growth and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
LL	Anticipating capacity - related problems	D&M Compliance server  External system	Fully done

Organization should ensure that backup copies of information, software, and systems are regularly maintained and tested, according to established policy on backups. This practice is important for recovering data or systems in case of loss. Organization should develop and implement plans for backing up information, software, and systems, considering factors such as business requirements,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Documenting and delegating ownership of own backup processes	Backup processes (3) 🔗 Technical cyber security	Fully done
DJ	Encryption of backup data	🔗 No security system linked	Fully done
DJ	Regular testing, evaluation, and recovery instructions for backups	Task owner shall ensure that the restoration o... 🔗 Process description	Fully done
DJ	Determining responsibilities for backing up important information assets	Data systems: Provider (7) 🖥️ System management	Fully done
DJ	Defining a backup strategy	Backup policy 📄 Report	Fully done

Organization needs to make sure there are backup systems in place for information processing to meet availability needs and keep operations running. The organization needs to plan and set up procedures for using redundant parts and facilities. Procedures should determine whether the redundant parts are always active or are activated automatically or manually in emergencies. It's important that redundant

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Basic service testing, fault tolerance evaluation and verification	Task owner plans, monitors, and updates the ...  Process description	Fully done
DJ	Definition and monitoring of alarm policies	 No security system linked	Fully done
K	Ensuring and testing the resilience of data processing environment	D&M test the resilient data processing enviro...  Process description	Fully done
SC	Multiple providers for critical network equipment	Diversification of service providers: To ensur...  Process description	Mostly done

5: Legal and compliance

5.31 Legal, statutory, regulatory and contractual requirements

Applicable: Based on risk treatment

The Organization should identify, document, and regularly update legal, statutory, regulatory, and contractual requirements pertinent to information security. This is crucial to ensure that the Organization remains in compliance with these standards, fulfilling its commitment to meeting legal obligations, industry regulations, and contractual agreements related to information security.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Identification, documentation and management of other information security requirements	Other requirements (11)  Risk management and leadership	Fully done
DJ	Compliance of used cryptographic controls in relation to applicable requirements	Compliance check for cryptographic controls:...  Process description	Fully done

5.32 Intellectual property rights

Applicable: Based on risk treatment

The organization should establish and implement procedures to safeguard intellectual property rights, ensuring compliance with legal, statutory, regulatory, and contractual requirements concerning intellectual property and the use of proprietary products. Asset registers should be maintained, identifying assets subject to intellectual property protection. Proof of ownership, including licenses and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Procedure for identifying software licensing requirements	The Organisation have a procedure for identif...  Process description	Fully done

The organization must implement measures to safeguard records against loss, destruction, falsification, unauthorized access, and unauthorized release. This is essential to meet legal, statutory, regulatory, and contractual requirements, as well as community or societal expectations concerning the protection and availability of records. Data storage systems should facilitate retrieval within an acceptable timeframe

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Documentation of data classes for data sets	Data sets: Class (15)  Management of data sets	Fully done
KH	Defining and documenting retention times for data sets	Data sets: Retention (15)  Management of data sets	Fully done
KH	Designation of data set owners	Data sets (15)  Management of data sets	Fully done
KH	Using data loss prevention policies	 No security system linked	Fully done

The organization should do independent reviews of its approach to managing information security, people, processes, and technologies. These reviews should be conducted at planned intervals or triggered by significant changes. The objective is to ascertain the ongoing suitability, adequacy, and effectiveness of the organization's information security management approach.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
KH	Executing and documenting internal audits	Audits (1)  Risk management and leadership	Fully done
DJ	Regular external auditing of security practices	Other stakeholders (5)  Partner management	Fully done

Regular reviews are essential to confirm adherence to the organization's information security policies, as well as topic-specific policies, rules, and standards. This ensures that information security is implemented and operated in alignment with the organization's overall information security framework. In the event of non-compliance, managers should identify causes, assess the need for corrective actions,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Monitoring compliance with security guidelines	Technical monitoring: The organization has i...  Process description	Fully done
DJ	Regular internal monitoring of the implementation of the information security management system	Monitoring task implementation: The ISMS (In...  Process description	Fully done
DJ	Regular penetration testing	D&M Compliance server  External system	Fully done
DJ	Regular vulnerability scanning	 OpenVPN  Google Cloud Identity & Access Management (IAM)  GitHub  External system	Fully done

Operating procedures for information processing facilities should be documented and accessible to relevant personnel to ensure correct and secure operations. Documented procedures should cover various operational activities related to information security, such as routine tasks performed by multiple individuals, infrequent tasks prone to being forgotten, new tasks with potential risks, and handovers to

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
KH	General security guidelines for staff	Using and updating mobile devices: The orga...  Process description	Fully done
KH	Monitoring compliance with security guidelines	Technical monitoring: The organization has i...  Process description	Fully done
KH	Continuous development of guidelines	Improvement of tools: The organization has i...  Process description	Fully done

6: Human resource security

6.1 Screening

Applicable: Based on risk treatment

Background verification checks should be conducted on all candidates prior to their employment and on an ongoing basis, adhering to relevant laws, regulations, and ethical considerations. This process should be proportional to business requirements, the sensitivity of accessed information, and perceived risks. Goal is to ensure personnel are eligible and suitable for their roles before and during employment.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Screenings and background checks before recruitment	Background check for cyber security applica...  Process description	Fully done

6.2 Terms and conditions of employment

Applicable: Based on risk treatment

Employment contracts should clearly outline both the responsibilities of personnel and the organization regarding information security. This is essential to ensure that personnel have a clear understanding of their information security responsibilities within their respective roles. Terms should be tailored to the level of access personnel will have to the organization's assets linked to information systems and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Defining cyber security responsibilities and tasks in employment contracts	Responsibilities and rights in employment con...  Process description	Fully done
KH	Maintaining confidentiality agreements	Definition of confidential information: The agr...  Process description	Fully done
KH	Reviewing confidentiality agreements	Regular review of requirements: The organiza...  Process description	Fully done

Organization personnel and relevant stakeholders must undergo suitable information security awareness, education, and training, along with regular updates on the organization's information security policy, topic - specific policies, and procedures relevant to their roles. This ensures that personnel and stakeholders are informed and capable of fulfilling their information security responsibilities.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Staff guidance and training procedure in cyber security	Personnel security guidelines and acceptance procedure  Report	Fully done
KH	Maintaining a log of cyber security trainings	Trainings and exercises (3)  Personnel security	Fully done
KH	Unit - or role - specific security guidelines	Role - specific security guidelines: The organi...  Process description	Fully done
KH	Continuous development of guidelines	Improvement of tools: The organization has i...  Process description	Fully done
KH	Evaluating the efficiency of arranged training	Competence evaluation: The organization has...  Process description	Mostly done

The organization should have a clear and communicated disciplinary process in place to address information security policy violations by personnel and other relevant parties. This ensures that everyone understands the consequences of such violations. The goal is to deter and appropriately handle individuals who breach the information security policy.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Disciplinary process for security breaches	Assessment of intentionality: The organizatio...  Process description	Fully done

Clear information security responsibilities and duties should be defined for personnel and other involved parties, ensuring their comprehension and enforcement even after employment termination or contract change. This safeguards the organization's interests during transitions in employment or contractual arrangements. The management of termination or change in employment should specify which

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Defining cyber security responsibilities and tasks in employment contracts	Responsibilities and rights in employment con...  Process description	Fully done
KH	Informing about cyber security responsibilities that continue after employment relationship has ended	Distinguishing security responsibilities in the ...  Process description	Fully done
KH	Training personnel with a changed role	Pre-access training for new roles: The organi...  Process description	Fully done

Clear and regularly reviewed confidentiality agreements, aligning with the organization's information protection requirements, should be identified, documented, and signed by personnel and other relevant parties. This ensures the continued confidentiality of information accessed by both internal and external entities. Considerations for these agreements include e.g. defining the information to be protected,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Maintaining confidentiality agreements	Definition of confidential information: The agr...  Process description	Fully done
KH	Reviewing confidentiality agreements	Regular review of requirements: The organiza...  Process description	Fully done

When working remotely, it's important to have security measures in place to protect information accessed, processed, or stored outside the organization's premises. This ensures the security of information even when personnel are working from locations away from the organization's physical offices. Organizations that permit remote working should establish a specific policy on remote work,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
SC	Acquisition and instructions for a VPN-service	 OpenVPN  External system	Fully done
DJ	Personnel guidelines for secure remote work	Remote work and mobile device guidelines (13)  Employee awareness	Fully done
SC	Arranging suitable equipment and storage equipment for teleworking	Provision of company-owned equipment: Th...  Process description	Fully done
SC	Defining suitable locations and needed protections for remote work	Locations suitable for teleworking and the ne...  Process description	Fully done
SC	Definition of measures permitted in remote work	Establishment of work classification guideline...  Process description	Fully done

7: Physical security

To safeguard information and associated assets, organizations should establish and utilize physical security perimeters for information processing facilities. They serve to prevent unauthorized physical entry and protect against potential damage or interference to the organization's valuable assets. External structures like roofs, walls, ceilings, and flooring should be sturdy, and external doors should be secured

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Physical access control to building, offices and other premises	Access to security restricted areas is only po...  Process description	Fully done
DJ	Security services in real estates	A distinct two-person mobile patrol patrols th...  Process description	Fully done
DJ	Strong authentication for processing or storage areas of highly confidential information	D&M Compliance server  External system	Fully done
DJ	Camera surveillance in real estates	Description not filled	Fully done

Secure areas need effective protection through suitable entry controls. This is crucial to guarantee that only authorized individuals gain physical access to the organization's information and associated assets. In order to ensure security, organization can e.g. restrict access to sites and buildings to authorized personnel only and with a comprehensive process for managing access rights. Organizations should

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Notification process in case of loss of physical identifiers	Actions taken when identifying a lost physical...  Process description	Fully done
DJ	Physical access control to building, offices and other premises	Access to security restricted areas is only po...  Process description	Fully done
DJ	Visitor instructions and log	<i>Description not filled</i>	Fully done
DJ	Using keys and other IDs that produce electronic movement log	D&M Compliance server  External system	Fully done
DJ	Using visible IDs	<i>Description not filled</i>	Fully done
DJ	Limited access and monitoring of support staff	External support staff, such as maintenance o...  Process description	Fully done

To mitigate the risk of unauthorized physical access, damage, and interference to an organization's information and associated assets within offices, rooms, and facilities, it is crucial to design and implement robust physical security measures. This can be done e.g. designing buildings to be discreet, with minimal indicators of their purpose to outsiders and restricting access to directories, internal

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Preventing eavesdropping	To prevent eavesdropping, the organization's ...  Process description	Fully done
DJ	Preventing unauthorized viewing personal data	The organization's premises are designed so ...  Process description	Fully done
DJ	Safe placement of equipment	Physical security policy  Report	Fully done
DJ	Strong authentication for processing or storage areas of highly confidential information	D&M Compliance server  External system	Fully done
DJ	Electromagnetic data breach management	Openings in the Hetzner' structures (windows...  Process description	Fully done

Continuous monitoring of premises is essential to detect and prevent unauthorized physical access. Monitoring system design should remain confidential to prevent break-ins, and access to surveillance information must be protected from unauthorized access. Systems should be securely placed and regularly tested, and compliance with local laws and regulations regarding data protection and privacy

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong



Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Continuous monitoring of physical access to critical facilities	Description not filled	Fully done
DJ	Security services in real estates	A distinct two-person mobile patrol patrols th...  Process description	Fully done
DJ	Camera surveillance in real estates	Description not filled	Fully done

Organizations should design and implement measures to protect against physical and environmental threats, encompassing both natural disasters and intentional or unintentional harm to infrastructure. The objective is to prevent or mitigate the consequences arising from events related to these threats. Before commencing critical operations at a physical site, and periodically thereafter, risk assessments should be

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong



Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Basic service testing, fault tolerance evaluation and verification	Task owner plans, monitors, and updates the ...  Process description	Fully done
DJ	Safe placement of equipment	Physical security policy  Report	Fully done

Security measures for working in secure areas should be carefully designed and implemented to safeguard information and associated assets from both damage and unauthorized interference by personnel operating within these areas. Security measures for working in secure areas must be followed by all personnel and should encompass all activities occurring within the secure area.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Guidelines for operating in processing areas for confidential information	Physical security guidelines (3)	Fully done
		 Employee awareness	

7.7 Clear desk and clear screen

Applicable: Based on risk treatment

Clear desk rules for papers and removable storage media, as well as clear screen rules for information processing facilities, should be established and enforced diligently. This is to mitigate the risks of unauthorized access, loss, and damage to information left on desks, screens, and other accessible locations, both during and outside normal working hours.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
KH	Personnel guidelines for safe processing of personal and confidential data	Privacy guidelines (5)	Fully done
		 Employee awareness	
DJ	Endpoint PIN-protection and automated locking	PIN protection and device auto-lock are enfor...	Fully done
		 Process description	

Off-site assets should be protected to prevent loss, damage, theft, or compromise of devices and to avoid interruptions to the organization's operations. These devices used outside the organization's premises (e.g. mobile devices) whether owned by the organization or privately owned and used on behalf of the organization (bring your own device BYOD), require protection. Their use should be

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Personnel guidelines for safe usage of mobile devices	Remote work and mobile device guidelines (13)  Employee awareness	Fully done
SC	Arranging suitable equipment and storage equipment for teleworking	Provision of company-owned equipment: Th...  Process description	Fully done
DJ	Enabling remote wipe on endpoint devices	 No security system linked	Fully done

7.11 Supporting utilities

Applicable: Based on risk treatment

To ensure the protection of information processing facilities, measures should be in place to safeguard against power failures and disruptions in supporting utilities (e.g. water supply, gas, sewage and ventilation). Implementation of robust strategies and safeguards is essential to maintain the integrity and continuity of information processing operations in the face of utility failures.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
LL	Anticipating capacity-related problems	D&M Compliance server  External system	Fully done
DJ	Basic service testing, fault tolerance evaluation and verification	Task owner plans, monitors, and updates the ...  Process description	Fully done
DJ	Alarm systems for equipment environment	 No security system linked	Fully done
DJ	Use of surge protectors and uninterruptible power supplies (UPS)	D&M Compliance server  External system	Fully done

7.12 Cabling security

Applicable: Based on risk treatment

Organizations should safeguard power and data cables to prevent interception, interference, or damage. This ensures protection against loss, theft, compromise of information, and interruptions to organizational operations related to power and communication cabling.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Cabling security	Power and communication cables that either ...  Process description	Fully done

Ensuring the proper maintenance of equipment is crucial to preserve the availability, integrity, and confidentiality of information. This practice helps prevent potential risks such as information loss, theft, or compromise, as well as disruptions to organizational operations due to maintenance lapses. This can be done e.g. by maintaining equipment in accordance with the supplier's recommended service

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Ensuring the quality of equipment maintenance	Task owner will ensure that guidelines are pro...  Process description	Fully done
DJ	Equipment maintenance log	Maintenance performed on the equipment is r...  Process description	Fully done

Before disposal or re-use, items of equipment containing storage media should be verified to ensure that any sensitive data and licensed software have been removed or securely overwritten. This way organizations can safeguard against unauthorized access to sensitive data and maintain the security of licensed software during the equipment lifecycle transitions. Storage media holding confidential or

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Safe disposal of laptops	Unnecessary laptops are collected by the IT d...  Process description	Fully done
KH	Process for secure disposal of removable media containing confidential information	D&M has a strict policy against the use of rem...  Process description	Fully done

8: System and network security

8.7 Protection against malware

Applicable: Based on risk treatment

Protection against malware should be ensured to safeguard information and associated assets. This involves utilizing malware detection and repair software, coupled with user awareness and appropriate controls. This can be done by e.g. implementing rules to prevent unauthorized software usage, reducing vulnerabilities and conducting regular scans for malware. Also configuring malware detection tools

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Selection and use of malware detection software on all devices	 GitHub D&M Compliance server  External system	Fully done
DJ	Automatically updating and running malware prevention software	Automated update check for malware protecti...  Process description	Fully done
DJ	Detecting and blocking access to dangerous websites	 No security system linked	Fully done
DJ	Procedures and data sources for gathering reliable information about malware	Malware protection policy  Report	Fully done
DJ	Regular malware inspection of data systems supporting critical business processes	Regular malware inspection in critical data sy...  Process description	Fully done
DJ	Automatic blocking and detecting of unauthorized software	 No security system linked	Fully done
DJ	Instructing and training staff regarding malware	Malware protection software utilization: The o...  Process description	Fully done
K	Training the use of security systems and reporting of malware attacks	Process for Training on the Use of Security S...  Process description	Mostly done

To protect information within networks and supporting systems, it's crucial to secure, manage, and control networks and network devices effectively. This involves implementing various controls to ensure the security of information passing over networks and to safeguard connected services from unauthorized access. Key considerations include defining responsibilities for network management,

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Determining the responsibility of network devices	Network and communications security policy  Report	Fully done
DJ	Documentation of other protected assets	Other assets (0)  Physical security Offices (5)  Physical security	Fully done
SC	Management of filtering and monitoring systems	D&M Compliance server  External system	Fully done
SC	Network usage log and process for detecting inappropriate network traffic	D&M Compliance server  External system	Fully done

To ensure the security of network services, organizations should identify, implement, and monitor security mechanisms, service levels, and requirements. This involves identifying the necessary security measures for specific services, such as authentication, encryption, and access controls, and ensuring their implementation by internal or external service providers. The organization should assess the

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Adequate

 Evidence: Medium

Owner	Task name	Evidence	Status
SC	Defined security arrangements for providing critical network equipment	Advanced definition of security arrangements...  Process description	Mostly done
DJ	Protection of wireless connections	D&M Compliance server  External system	Fully done
SC	Multiple providers for critical network equipment	Diversification of service providers: To ensur...  Process description	Mostly done

In the organization's networks, it's good to separate groups of information services, users, and information systems. This segregation helps create security boundaries and control traffic between them according to business needs. Organizations can consider partitioning large networks into distinct network domains and isolating them from the public internet. Access between network domains, if

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
SC	Network areas and structurally secure network design	Network ownership: The organization has def...  Process description	Fully done
DJ	Separation of critical environments	Technical environment isolation: The organiza...  Process description	Fully done

Access to external websites should be managed to minimize exposure to malicious content, this safeguards systems from malware and unauthorized web resources. Organizations can achieve this by blocking access to websites with illegal content, viruses, or phishing material using techniques like IP or domain blocking. Certain browsers and anti-malware technologies can automate this process or be

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Detecting and blocking access to dangerous websites	 No security system linked	Fully done

To minimize the impact of audit and other assurance activities on operational systems and business processes, it's crucial to plan and agree on these activities between the tester and appropriate management. Guidelines for this include controlling the scope of technical tests, and limiting tests to read-only access whenever possible. Audit tests that could affect system availability should be

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Protection of data systems during audit-related testing	Advance planning and agreement: The organi...  Process description	Fully done

Data about information security threats needs to be gathered and examined to generate threat intelligence. This intelligence helps in understanding the organization's threat landscape and implementations of suitable actions to mitigate these threats. Threat intelligence should get integrated into the information security risk management processes, influence technical security controls, and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	The goals of threat intelligence and the collection of information related to information security threats	Conducting threat intelligence: The organizati...  Process description	Fully done
DJ	Regular analysis and utilization of information related to information security threats	Conducting threat intelligence: The organizati...  Process description	Fully done
DJ	Consideration of threat intelligence findings in the information security risk management process	Integration of threat intelligence findings: The...  Process description	Fully done
DJ	Sharing threat intelligence	Establishment of threat intelligence sharing n...  Process description	Fully done

To prevent exploitation of technical vulnerabilities, organizations should proactively identify, evaluate, and address potential vulnerabilities in their information systems. This can be done for example by maintaining an accurate inventory of assets, including software versions and responsible personnel and utilising various resources to identify vulnerabilities, such as vulnerability scanning tools and penetration

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Process for managing technical vulnerabilities	Process for addressing technical vulnerabiliti...  Process description	Fully done
DJ	Initial treatment of identified technical vulnerabilities	Quick-response team setup: The organizatio...  Process description	Fully done
DJ	Regular penetration testing	D&M Compliance server  External system	Fully done
DJ	Regular vulnerability scanning	 OpenVPN  Google Cloud Identity & Access Management (IAM)  GitHub  External system	Fully done
SC	Selecting and tracking data sources for vulnerability information	Identification of Information sources: The org...  Process description	Fully done
DJ	Evaluating and testing patches before deployment	 No security system linked	Fully done
DJ	Management process for software updates	 No security system linked	Fully done
KH	Regular monitoring of the vulnerability management process	Regular monitoring of vulnerability managem...  Process description	Fully done

8, 5 & 6: Information security event management

The organization needs to assess information security events to determine whether they should be categorized as information security incidents. This process ensures the effective categorization and prioritization of information security events. Those responsible with coordinating and responding to information security incidents should assess the events and determine appropriate actions.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Designation of an incident management team	Instruction and training of incident managem...  Process description	Fully done
K	The first level response process to security incidents	First level response: The organization has est...  Process description	Fully done

The organization must respond to information security incidents, following documented procedures to ensure a prompt and effective response to these incidents. The response to an information security incident can involve containing the incident, collecting evidence, escalating as needed, logging activities, coordinating with internal and external entities, closing the incident formally, conducting forensic

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Treatment process and documentation of occurred security incidents	Security incidents (2)  Incident management	Fully done
K	Process for initiating data breach treatment	Pre - defined breach response team: The orga...  Process description	Fully done

Knowledge gained from information security incidents should be leveraged to strengthen and improve information security controls, aiming to reduce the likelihood or consequences of future incidents. The organization should establish procedures to quantify and monitor information security incidents in terms of types, volumes, and costs. This information is utilized to enhance incident management plans, identify

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Communicating the results of cyber security incident analysis	Informing original reporter and involved perso...  Process description	Fully done
K	Follow-up analysis for security incidents	Follow-up analysis: The organization has perf...  Process description	Fully done
K	Regular periodic analysis and learning of incidents	Regular incident analysis: The organization ha...  Process description	Fully done

The organization should develop and implement procedures for identifying, collecting, acquiring, and preserving evidence related to information security events. These procedures aim to ensure a consistent and effective management of evidence, particularly for disciplinary and legal actions resulting from information security incidents.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
K	Disciplinary process for security breaches	Assessment of intentionality: The organizatio...  Process description	Fully done
K	Managing evidence information for information security incidents	 Process: Managing Evidence for Informati...  Process description	Fully done

The organization should have a way for its personnel to report any observed or suspected information security events (incidents, breaches, and vulnerabilities) promptly through proper channels. This ensures quick, consistent, and effective reporting of events. All personnel and users must understand their duty to promptly report information security events to prevent or mitigate the impact of incidents.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
K	Personnel guidelines for reporting security incidents	Incident management guidelines (7)  Employee awareness	Fully done

Logs recording various events must be created, stored, protected, and analyzed to e.g. generate evidence and identify potential security incidents. The organization should establish a dedicated logging policy outlining log purposes, collected data, and protection requirements. Event logs should encompass user IDs, system activities, event timestamps, device/system identifiers, and network details.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Documentation of system logs for self-maintained data systems	System logs (5)  Technical cyber security	Fully done
DJ	Data system log review	Awareness of logs: The organization has a co...  Process description	Fully done
DJ	Definition and monitoring of alarm policies	 No security system linked	Fully done
DJ	Deployment and regular analysis of security system logs	D&M Compliance server  External system	Fully done
DJ	Protecting log information	The logs are protected from unauthorized cha...  Process description	Fully done
DJ	Automatic log data analyzation	 GitHub MT logs Hetzner Filrewalll Logs Analyses  External system	Fully done

Networks, systems, and applications must undergo continuous monitoring to detect any abnormal behavior and promptly address potential information security incidents. The scope and intensity of monitoring should align with business and security needs, while also adhering to relevant laws and regulations. Components to monitoring system can include analysis of inbound and outbound traffic

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Determining the baseline for network and data system usage for monitoring purposes	Monitoring during normal and peak times: Th...  Process description	Fully done
DJ	Information sharing related to network and data systems usage anomalies	Anomalies is reported to the relevant parties i...  Process description	Fully done
DJ	Monitoring the use of the network and information systems to identify anomalies	Hetzner Filrewalll Logs Analyses D&M Compliance server  External system	Fully done

The organization should synchronize the clocks of its information processing systems with approved time sources to facilitate event correlation, data analysis, and incident investigations. A standard reference time should be established and applied consistently across all systems, including building management and access control systems, to support investigations effectively.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Clock synchronization	Use of Network Time Protocol (NTP): The org...  Process description	Fully done

8: Secure configuration

8.9 Configuration management

Applicable: Based on risk treatment

The organization must establish and implement processes and tools to enforce configurations, especially security configurations, across hardware, software, services, and networks for both new and operational systems. Goal is to guarantee the proper functioning of hardware, software, services, and networks while maintaining necessary security configurations, and to prevent unauthorized or erroneous

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Configuration management and change log	Configuration documentation: The organizati...  Process description	Fully done
DJ	Defining standard templates for secure configurations	Defining standard templates for secure config...  Process description	Fully done
DJ	Monitoring configurations	Requirements for Monitoring ConfigurationsM...  Process description	Fully done

Organisation should limit and closely control the use of utility programs that can override system and application controls. This is to prevent any potential harm to information security controls caused by the use of such utility programs. Guidelines include limiting access to trusted users, implementing identification and authentication procedures, documenting authorization levels, and authorizing ad hoc

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Limitation of privileged utility programs	Purpose:The purpose of limiting privileged uti...  Process description	Fully done

Secure procedures and measures must be in place for installing software on operational systems. This safeguards the integrity of the systems and prevents the exploitation of technical vulnerabilities. Secure management of changes and software installations can include authorized updates by trained administrators with appropriate management approval, extensive testing before installing or updating

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Separation of production, testing and development environments	Development work is divided into three distin...  Process description	Fully done
DJ	Authorized users and rules for installing software and libraries	Restrictions on software installations: The org...  Process description	Fully done
DJ	Listing authorized users for publishing code changes	Only pre - defined, authorized users are allow...  Process description	Fully done
DJ	Maintaining a release log	 GitHub  External system	Fully done

Organisation needs to establish and enforce clear rules for cryptography and key management to safeguard information confidentiality, authenticity, and integrity in alignment with business and security needs. Compliance with legal and regulatory requirements ned to be ensured related to cryptography. Service level agreements or contracts with external suppliers of cryptographic services should address

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Encryption of backup data	 No security system linked	Fully done
DJ	Encryption of laptops	 No security system linked	Fully done
DJ	Encryption of portable media	Use of portable media is not allowed in the or...  Process description	Fully done
DJ	Encryption of user password information	 No security system linked	Fully done
DJ	General, risk -based encryption policy	Encryption policy  Report	Fully done
DJ	Revision of encryption methods and assessment of adequacy	Consideration of encryption costs: The organi...  Process description	Fully done

8: Application security

The establishment and application of rules for secure software and system development are crucial to ensure information security throughout the development lifecycle. Key aspects to consider include separation of environments, adherence to secure coding guidelines, integration of security requirements into specifications and design, implementation of security checkpoints, rigorous testing, secure source

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Guidelines for secure development	Secure development and technical vulnerability management policy  Report	Fully done
KH	Listing offered digital services and naming owners	Offered cloud services (1)  Development and cloud	Fully done

When creating or obtaining applications, it's important to identify, outline, and approve information security requirements. This ensures that all necessary security needs are recognised and taken into account during the application development or acquisition process. These requirements typically come from risk assessment process, which should involve the expertise of information security specialists.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Encryption of public network traffic for application services	 1Password  Google Authenticator  OpenVPN  IONOS cloud  GitHub Hetzner Filrewalll Logs Analyses D&M Compliance server  External system	Fully done
DJ	Encryption of user password information	 <i>No security system linked</i>	Fully done
DJ	Security rules for the development and acquisition of data systems	Task owner is involved in purchasing decision...  Process description	Fully done

Organisation should create, document, and uphold principles for building secure systems in all information system development activities. This ensures that information systems are designed, implemented, and operated securely throughout their development life cycle. Security should be integrated into every layer of architecture, including business, data, applications, and technology.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Guidelines for secure development	Secure development and technical vulnerability management policy  Report	Fully done
DJ	Regular critical code identification and verification	New parts of the critical code are constantly ...  Process description	Fully done

When creating software, it's important to follow secure coding principles. This helps ensure that the software is written in a secure manner, reducing the chances of having potential vulnerabilities that could compromise information security. These procedures should be broadened to encompass software components sourced from third parties and open-source software. Organisation needs to implement

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Separation of production, testing and development environments	Development work is divided into three distin...  Process description	Fully done
DJ	General rules for reviewing and publishing code	General rules for reviewing, approving and pu...  Process description	Fully done
DJ	Guidelines for secure development	Secure development and technical vulnerability management policy  Report	Fully done
DJ	Regular vulnerability scanning	 OpenVPN  Google Cloud Identity & Access Management (IAM)  GitHub  External system	Fully done
DJ	Vulnerability monitoring in used third-party or open source libraries	D&M Compliance server  External system	Fully done

In the development process, it's essential to establish and follow security testing procedures. These processes ensure that when applications or code are deployed to the production environment, they are thoroughly tested to confirm they meet information security requirements. Tests should align with specified requirements, covering both functional and non-functional aspects.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Definition of done and testing principles	The development unit itself maintains a list of ...  Process description	Fully done
DJ	Regular penetration testing	D&M Compliance server  External system	Fully done
DJ	Regular vulnerability scanning	 OpenVPN  Google Cloud Identity & Access Management (IAM)  GitHub  External system	Fully done

Development, testing, and production environments must be kept separate and secured to safeguard the production environment and data from potential compromise during development and testing activities. The necessary level of separation between these environments should be identified and enforced to prevent any issues from affecting production systems.

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Medium

Owner	Task name	Evidence	Status
DJ	Separation of production, testing and development environments	Development work is divided into three distin...  Process description	Fully done
DJ	Source code management	 No security system linked	Fully done

Any changes made to information processing facilities and systems should follow established change management procedures. This is done to maintain and ensure information security while implementing changes. Change control procedures must be documented and enforced to safeguard the confidentiality, integrity, and availability of information across information processing facilities and

Your current coverage

Active tasks currently used to support this requirement.

Coverage: Strong

 Evidence: Strong

Owner	Task name	Evidence	Status
DJ	Change management procedure for significant changes to data processing services	Change risk assessments (3)  Risk management and leadership	Fully done
DJ	Evaluation process and documentation of significant security-related changes	Change risk assessments (3)  Risk management and leadership	Fully done
DJ	General rules for reviewing and publishing code	General rules for reviewing, approving and pu...  Process description	Fully done
DJ	Restoration strategy	Secure development and technical vulnerability management policy  Report	Fully done